

Security Operations Center

Lab 2: Blue and red teaming deep dive

Agenda

Part I	Introduction to blue teaming concepts	1 hour
Break		10 minutes
Part II	Introduction to red teaming concepts	45 minutes
Part III	SOC emulation lab set-up tests	15 minutes

Lecture goals

The lecture aims to achieve the following goals:

1. Provide a definition of what blue and red teaming is
2. Provide a high-level, albeit broad, overview of key blue and red teaming concepts
3. Provide the foundations to prepare for the upcoming practical lab exercises
4. Test the connectivity of the HSLU SOC lab

Part I

Introduction to Blue Teaming concepts

What is blue teaming

Definition

*"A group of individuals that conduct operational **network vulnerability evaluations** and **provide mitigation techniques** to customers who have a need for an independent technical review of their network security posture.*

*The Blue Team **identifies security threats and risks** in the operating environment, and in cooperation with the customer, analyses the network environment and its current state of security readiness. Based on the Blue Team findings and expertise, they **provide recommendations** that integrate into an overall community security solution **to increase** the customer's **cybersecurity readiness** posture.*

Often times a Blue Team is employed by itself or prior to a Red Team employment to ensure that the customer's networks are as secure as possible before having the Red Team test the systems."

From the [National Institute of Standards and Technology, Information Technology Laboratory, Computer Security Resource Centre](#)'s glossary of terms

Why use blue teaming

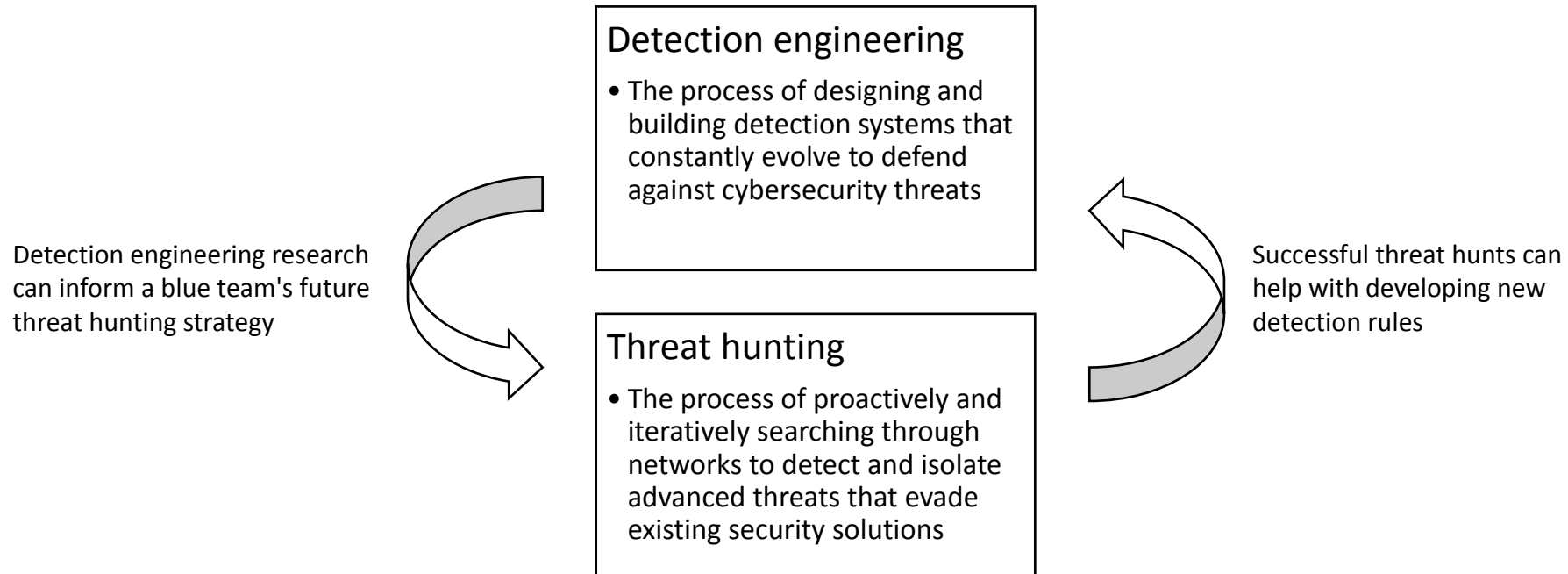
Concretely, in order to fulfil its mission of increasing an organisation's cybersecurity readiness, a blue team will be performing the below activities:

- A standby incident response capability ready to intervene in a moment's notice
- Operating system hardening
- Vulnerability management
- Perimeter defense
- IT network monitoring
- Participation in purple teaming exercises jointly with the red team

Perimeter defense and **IT network monitoring** are the focus of this lecture

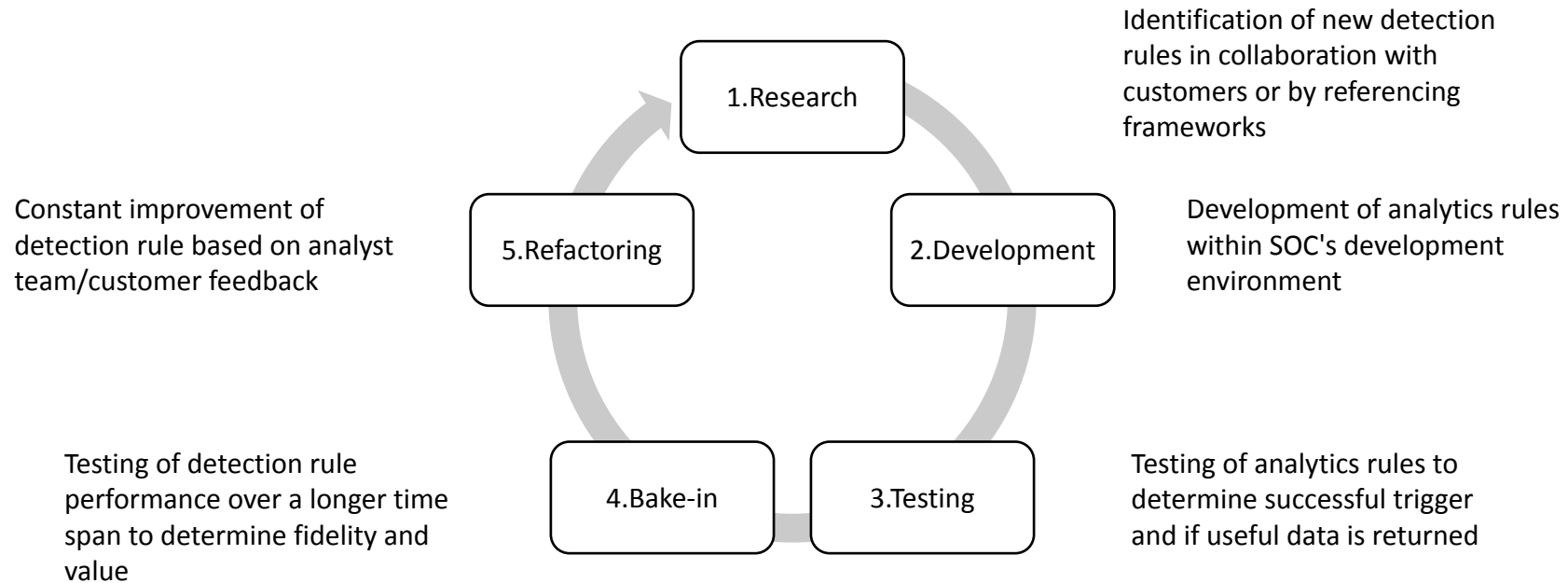
Overview of key blue teaming concepts

In order to deliver effective perimeter defense and IT network monitoring the blue team must consistently deliver high fidelity detection analytics that, once deployed, will help the SOC reliably detect malicious activity affecting an Organisation's IT assets. There are two key activities that a blue team must perform in order to deliver detection analytics as described in the below image:



Detection engineering lifecycle

In order to develop high-fidelity detections a blue team should follow a number of key steps as outlined in the image below:



Detection engineering – practical example

In order to successfully research and develop high fidelity detection rules a blue team must:

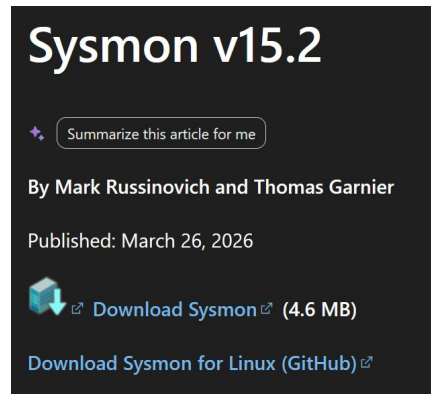
- I. Leverage reliable frameworks to identify potential detections for implementation
- II. Have deployed a working cybersecurity detection technology

In our SOC emulation lab we will create high fidelity detection rules by using two industry leading solutions, as described below:

Reference framework



Detection technology



Detection engineering – ATT&CK overview

Definition

“ A framework for describing the behaviour of cyber adversaries operating within enterprise networks ”

- Comprehensive library of "what to look for"
- Threat model and framework
- Library of adversary behaviour covering > 500 techniques across several operating systems and cloud platforms

Website: <https://attack.mitre.org>

ATT&CK is a knowledge base of adversary behaviours based on **real-world observations**. It describes adversary behaviours according to tactics, techniques and procedures (TTPs):

- # Enterprise Matrix

Below are the tactics and techniques representing the MITRE ATT&CK® Matrix for Enterprise. The matrix contains information for the following platforms: Windows, macOS, Linux, PRE, AWS, GCS Azure, Azure AD, Office 365, SaaS, Network.

View on the ATT&CK® Navigator [x](#)
 About the Enterprise domain
 Version Normalisk

layouts ▾
 show sub-techniques ▾
 hide sub-techniques ▾
 help

Reconnaissance 10 techniques	Resource Development 8 techniques	Initial Access 9 techniques	Execution 10 techniques	Persistence 16 techniques	Privilege Escalation 12 techniques	Defense Evasion 29 techniques	Credential Access 29 techniques	Discovery 29 techniques	Lateral Movement 9 techniques	Collection 17 techniques	Command and Control 18 techniques	Exfiltration 9 techniques	Impact 13 techniques
Active Scanning (1)	Acquire Infrastructure (2) Compromise Accounts (2)	Deliver Compromise Engine Public Facing Application External Remote Services Hardware Additions Phishing (3) Feasible Accounts (2) Covert Victim Network Information (2) Search Closed Sources (1)	Command and Scripting Interpreter (2) Exploitation for Client Execution JavaProcess Communication (2) Native API Scheduled Task (2) Shared Modules System Deployment Tools Software Services (2) User Execution (2) Windows Management Instrumentation	Account Manipulation (1) BITS Jobs Boot of Logon Automation Credential Access (2) Boot of Logon Scripts (2) Root of Logon Installation Scripts (2) Browser Extensions Component Client System Process (2) Credentials Local or Modify System Process (2) Domain Policy Modification (2) External Proxy (2) Event Triggered Execution (2) File Deletion (2) Hidden Files (2) Insecure Service (2) Invalid Account (2) Internal Container Image Offsite Application Startup (2) Pre OS Boot (2) The OS Boot (2) Scheduled Task (2) Server Software Component (2) Traffic Signaling (2) Valid Account (2)	Abuse Elevation Privilege (2) Access Token Manipulation (2) Root of Logon Automation (2) Root of Logon Installation Scripts (2) Root of Logon Validation Scripts (2) Create or Modify System Process (2) Domain Policy Modification (2) Event Triggered Execution (2) File Deletion (2) Hidden Files (2) Insecure Service (2) Invalid Account (2) Internal Container Image Offsite Application Startup (2) Pre OS Boot (2) The OS Boot (2) Scheduled Task (2) Server Software Component (2) Traffic Signaling (2) Valid Account (2)	About Election Control Mechanism (2) Host Fingerprint (2) Credentials from Application Window	Account Discovery (2) Exploitation of Remote Services	Exploitation of Remote Services	Archive Collected Data (2)	Application Layer Protocol (2)	Automated Exfiltration (2)	Account Access Removal	

Drive-by Compromise

Adversaries may gain access to a system through a user visiting a website over the normal course of browsing. With this technique, the user's web browser is typically targeted for exploitation, but adversaries may also use compromised websites to non-exploitation behavior such as acquiring Application Access Tokens.

Multiple ways of delivering exploit code to a browser exist, including:

 - A legitimate website is compromised where adversaries have injected some form of malicious code such as JavaScript, frames, and cross-site scripting.
 - Malicious ads are paid for and served through legitimate ad providers.
 - Built-in web application interfaces are leveraged for the insertion of any other kind of object that can be used to display web content or content that executes on the visiting client (e.g. forum posts, comments, and other user-controllable web content).

Often the website used by an adversary is one visited by a specific community, such as government, a particular industry, or region, where the goal is to compromise a specific user or set of users based on a shared interest. This kind of targeted attack is referred to as a strategic web compromise or watering hole attack. There are several known examples of this occurring.^[1]

Typical drive-by compromise processes:

 - A user visits a website that is used to host the adversary controlled content.
 - Scripts automatically execute, typically searching versions of the browser and plugins for a potentially vulnerable version.
 - The user may be required to assist in this process by enabling scripting or active website components and ignoring warning dialog boxes.
 - Upon finding a vulnerable version, exploit code is delivered to the browser.
 - If exploitation is successful, then it will give the adversary code execution on the user's system unless other protections are in place.
 - In some cases a second visit to the website after the initial scan is required before exploit code is delivered.

Offsite Explicit Pacing Application, the focus of this technique is to exploit software on a client endpoint upon visiting a website. This will commonly give an adversary access to systems on the internal network instead of external systems that may be in a DMZ.

Adversaries may also use compromised websites to deliver a user to the malicious application designed to steal Application Access Tokens, like OAuth tokens, to gain access to protected applications and information. These malicious applications have been delivered through popups on legitimate websites.^[2]

Procedures Examples

Name	Description
APT19	APT19 performed a watering hole attack on forbes.com in 2014 to compromise targets. ^[3]
APT32	APT32 has infected victims by tricking them into visiting compromised watering hole websites. ^[4]
APT37	APT37 has used strategic web compromises, particularly of South Korean websites, to distribute malware. The group has also used torrent file-sharing sites to more indiscriminately spread their payload called RICEURRY to profile a victim's web browser and deliver malicious code accordingly. ^{[5][6]}
APT38	APT38 has conducted watering holes schemes to gain initial access to victims. ^[7]

Screenshots of ATT&CK's matrix and a procedure description subpage

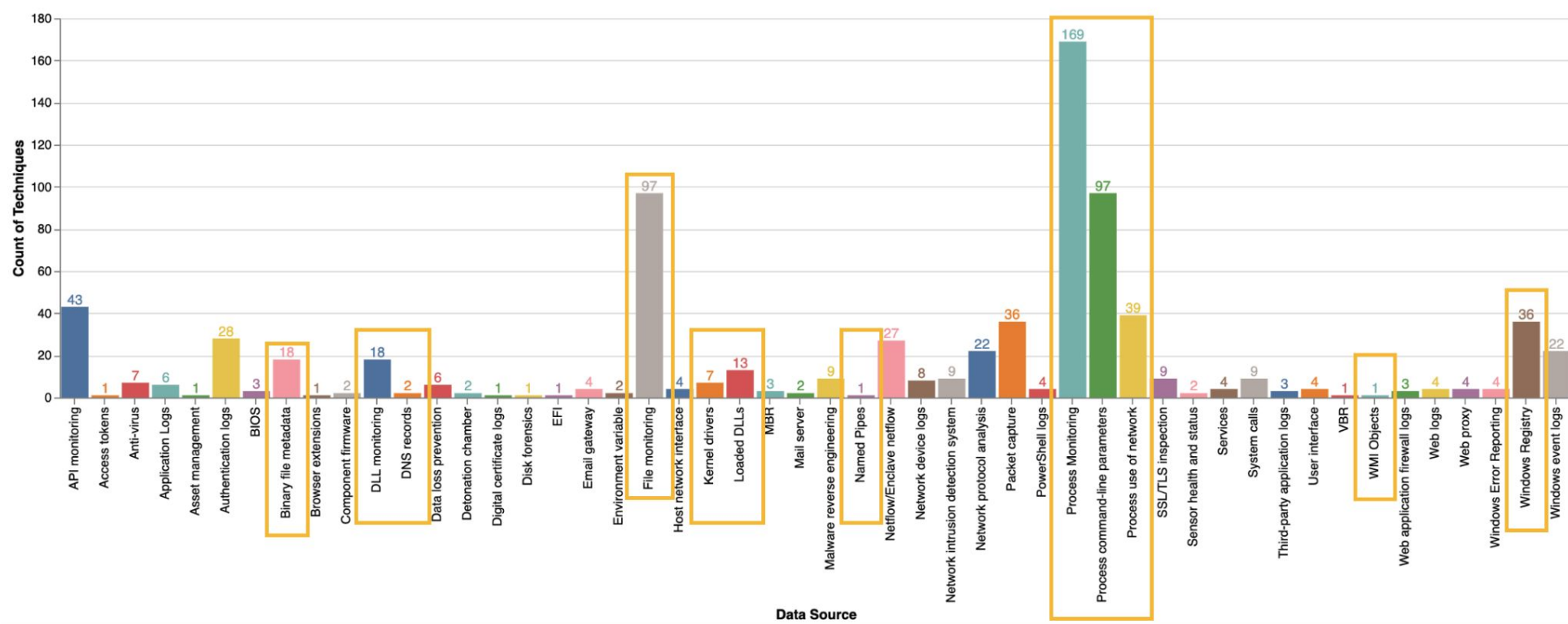
Detection engineering – How to use ATT&CK

ATT&CK drastically simplifies the creation of detection queries aimed at detecting techniques used by attackers in real life, as demonstrated in the simple example below:

Our objective	Tactic	Technique	Procedure	Detection rule																								
We want to develop high-fidelity analytics to detect techniques an adversary may use to gain knowledge about the system and internal network of our company	The techniques used by adversaries to extract network information are described under the ATT&CK's discovery tactic group MITRE ATT&CK TACTICS Enterprise Reconnaissance Resource Development Initial Access Execution Persistence Privilege Escalation Defense Evasion Credential Access Discovery Lateral Movement Collection Command and Control Exfiltration Impact Mobile	Using ATT&CK we understand that three discovery techniques are used, we choose to focus on Domain group discovery ATT&CK Matrix for Enterprise layouts show sub-techniques hide sub-techniques on Defense Evasion Credential Access Discovery Lateral Movement 27 techniques 18 techniques 9 techniques Blue Print Credentials from Personal Store EvilWinRM Process Injection Domain Policy Modification Execution Guardrails File and Directory Permissions Modification File and Directory Permissions Modification Hide Artifacts Inject Execution Flow Inject Defenses Indicator Removal on Host Indirect Command Execution Macrospreading Modify Authentication Protocol Modify Cloud Compute Infrastructure Account Discovery Application Window Discovery Browser Bookmark Discovery Cloud Infrastructure Discovery Cloud Service Discovery Domain Trust Discovery File and Directory Discovery Network Service Scanning Network Share Discovery Network Sniffing Password Policy Discovery Peripherals Device Discovery Permission Groups Discovery Process Discovery Query Registry Remote System Discovery Software Discovery Exploitation of Remote Services Internal Spreading Lateral Tool Transfer Remote Service Browser Hijacking Remote Services Replication Through Remote Media Software Deployment Tools Task Shared Context Use Alternate Authentication Methods	The procedure page tells us that a number of adversary groups use the net.exe utility to perform domain group discovery Permission Groups Discovery: Domain Groups Other sub-techniques of Permission Groups Discovery (3) Adversaries may attempt to find domain-level groups and permission settings. The knowledge of domain-level permission groups can help adversaries users belong to a particular group. Adversaries may use this information to determine which users have elevated permissions, such as domain administrator. Commands such as net.exe can be used to query the local utility, dsquery can be used to query groups on macOS, and dsquery can be used to query groups on Linux can list domain-level groups. Procedure Examples <table><tr><th>Name</th><th>Description</th></tr><tr><td>AdFind</td><td>AdFind can enumerate domain groups [1][2]</td></tr><tr><td>Bloodhound</td><td>Bloodhound can collect information about domain groups and members [3]</td></tr><tr><td>CrackMapExec</td><td>CrackMapExec can gather the user accounts within domain groups [4]</td></tr><tr><td>Driftnet 2.0</td><td>Driftnet 2.0 is used to batch scripts to enumerate administrators and users in the domain [5]</td></tr><tr><td>discovery</td><td>discovery can be used to gather information on permission groups within a domain [6]</td></tr><tr><td>FIND</td><td>FIND has used tools like AdFind to query users, groups, organizational units, and trusts [7]</td></tr><tr><td>GRIFON</td><td>GRIFON has used a reconnaissance module that can be used to retrieve Windows domain membership information [8]</td></tr><tr><td>Havestrch</td><td>Havestrch has checked for the domain admin group and Exchange Trusted Subsystem groups using the commands net user and net group [9]</td></tr><tr><td>Inspection</td><td>Inspection has used specific malware modules to gather domain membership [10]</td></tr><tr><td>Katiching</td><td>Katiching performs discovery of permission groups get_group_members [11]</td></tr><tr><td>Kwapiapi</td><td>Kwapiapi collects a list of domain groups with the command get_group_members [12]</td></tr></table>	Name	Description	AdFind	AdFind can enumerate domain groups [1][2]	Bloodhound	Bloodhound can collect information about domain groups and members [3]	CrackMapExec	CrackMapExec can gather the user accounts within domain groups [4]	Driftnet 2.0	Driftnet 2.0 is used to batch scripts to enumerate administrators and users in the domain [5]	discovery	discovery can be used to gather information on permission groups within a domain [6]	FIND	FIND has used tools like AdFind to query users, groups, organizational units, and trusts [7]	GRIFON	GRIFON has used a reconnaissance module that can be used to retrieve Windows domain membership information [8]	Havestrch	Havestrch has checked for the domain admin group and Exchange Trusted Subsystem groups using the commands net user and net group [9]	Inspection	Inspection has used specific malware modules to gather domain membership [10]	Katiching	Katiching performs discovery of permission groups get_group_members [11]	Kwapiapi	Kwapiapi collects a list of domain groups with the command get_group_members [12]	We build our query so that it targets the specific procedure as described in ATT&CK <pre>// Name: Account Discovery // Description: Checks for execution of MITRE ATT&CK T1087 // // Severity: High // // QueryFrequency: 1h // // QueryPeriod: 1h // // AlertTriggerThreshold: 1 // // DataSource: #Sysmon // // Tactics: #Discovery // // Sysmon where EventID == 1 and (process_path contains "net.exe" or process_path contains "powershell.exe") and (process_command_line contains "*net* user*" or (process_command_line contains "*net* group*" or process_command_line contains "*net* localgroup*" or process_command_line contains "cmdkey*\\list*" or process_command_line contains "*get-localuser*" or process_command_line contains "*get-localgroupmembers*" or process_command_line contains "*get-aduser*" or process_command_line contains "query*user*"))</pre>
Name	Description																											
AdFind	AdFind can enumerate domain groups [1][2]																											
Bloodhound	Bloodhound can collect information about domain groups and members [3]																											
CrackMapExec	CrackMapExec can gather the user accounts within domain groups [4]																											
Driftnet 2.0	Driftnet 2.0 is used to batch scripts to enumerate administrators and users in the domain [5]																											
discovery	discovery can be used to gather information on permission groups within a domain [6]																											
FIND	FIND has used tools like AdFind to query users, groups, organizational units, and trusts [7]																											
GRIFON	GRIFON has used a reconnaissance module that can be used to retrieve Windows domain membership information [8]																											
Havestrch	Havestrch has checked for the domain admin group and Exchange Trusted Subsystem groups using the commands net user and net group [9]																											
Inspection	Inspection has used specific malware modules to gather domain membership [10]																											
Katiching	Katiching performs discovery of permission groups get_group_members [11]																											
Kwapiapi	Kwapiapi collects a list of domain groups with the command get_group_members [12]																											

Detection engineering – ATT&CK application

ATT&CK and Sysmon form a perfect match when it comes to developing high-fidelity detections. This is because Sysmon's events detect up to 12 data sources that fall within the scope of techniques described in ATT&CK



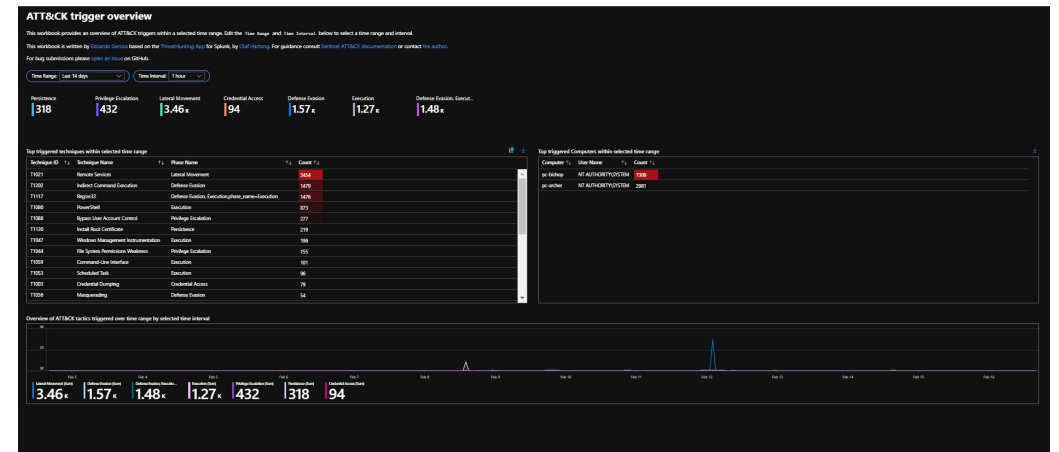
By using ATT&CK and Sysmon we can develop up to 117 detection queries that cover >30% of the available ATT&CK techniques. Each detection query can be mapped 1-to-1 to a specific ATT&CK technique

[illegible]

Detection engineering – dashboards

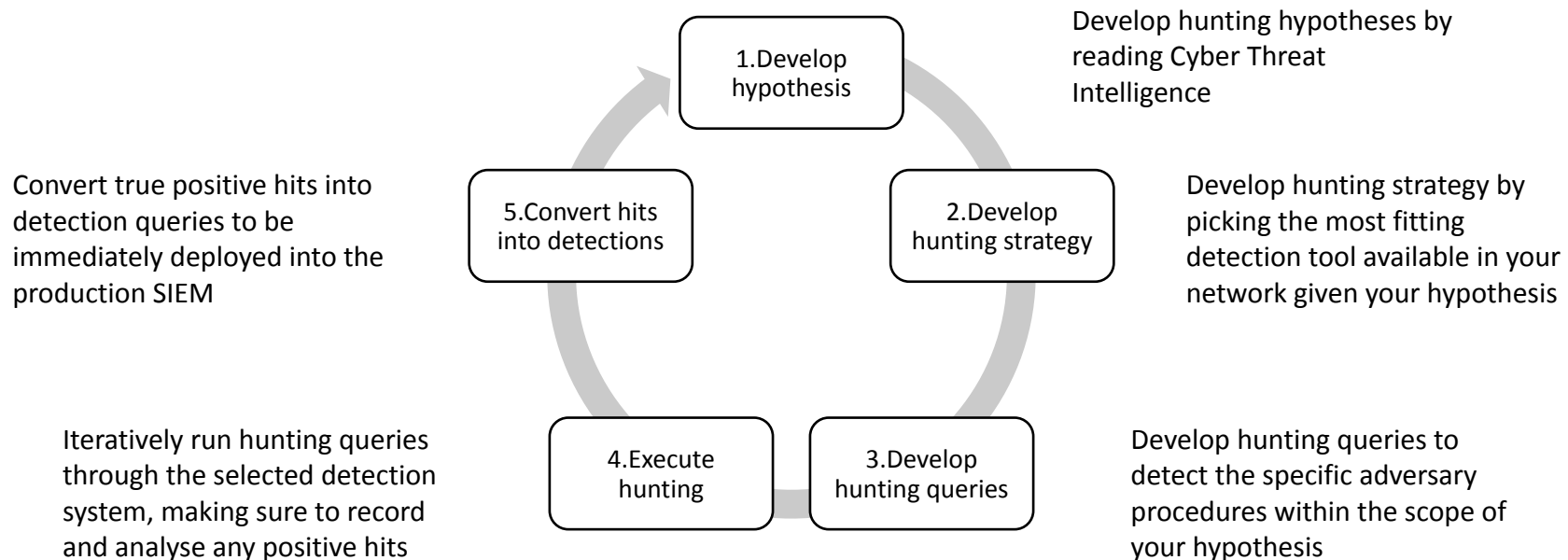
Combined together, Sysmon, ATT&CK and SIEMs can be used to build rich dashboards to monitor for the execution of specific ATT&CK techniques within the organisation's network estate. Dashboards offer the below advantages:

- Automation and standardisation of analysis
- Ability to deep dive by using dashboard drilldowns
- Observation of ATT&CK techniques over long periods
- Simplification of hunting activities
- Retroactive hunting



Threat hunting life cycle

The threat hunting lifecycle aims not only to detect and isolate threats within a network by following a proactive strategy, it also aims to derive high-fidelity detection rules on the back of successful hunting queries, as described in the image below:



Threat hunting – practical example

In order to successfully research and develop an effective threat hunting hypothesis a blue team must:

- I. Leverage reliable sources of intelligence to derive accurate hunting hypotheses
- II. Have deployed a working cybersecurity detection technology that enables proactive hunting

In the context of threat hunting, cyber threat intelligence (CTI) reports become central to the creation of accurate hypotheses. Framework's such as MITRE ATT&CK become less valuable compared to CTI reports as it takes a long time for MITRE to update the ATT&CK framework. CTI reports provide a source of intelligence that can be immediately used to execute threat hunts without waiting for ATT&CK to be updated.

Threat hunting – CTI overview

Definition

Cyber threat intelligence is "*information about threats and threat actors that provides sufficient understanding for mitigating a harmful event*"

Understanding Cyber Threat Intelligence Operations, Version 2.0, 2016, Bank of England

At its core, threat intelligence is designed to:

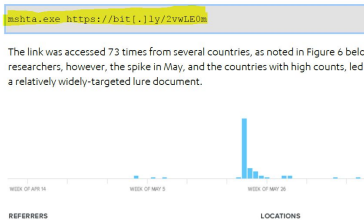
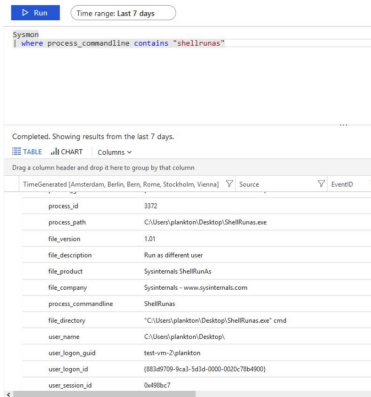
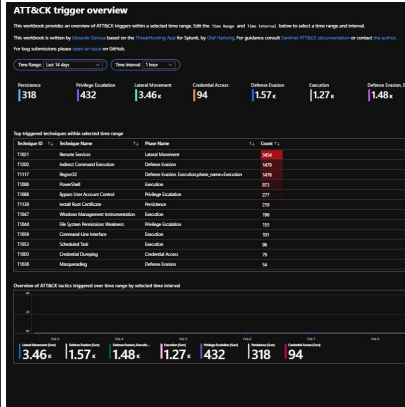
1. Define problems about existing or emerging threats
2. Gain evidence-based knowledge
3. Provide reasoned insight into future conditions
4. Drive security operations
5. Enable informed business decisions



Screenshots of sample threat intelligence reports

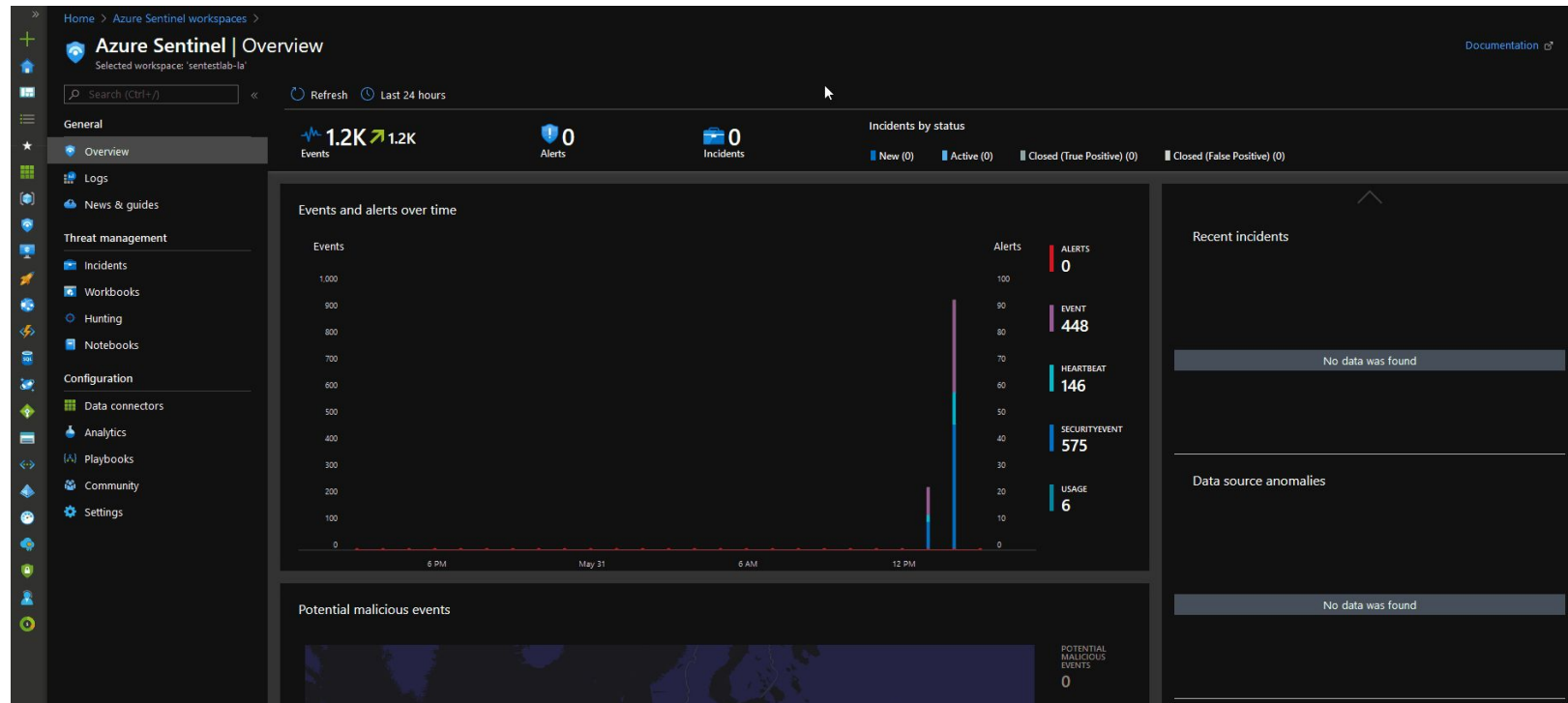
Threat hunting – How to use CTI

CTI reports aid the creation of hunting hypotheses aimed at detecting techniques used by attackers in real life and not yet widely reported, as demonstrated in the simple example below:

CTI consumption	Hypothesis	Hunt development	Hunt execution	Detection rule
SOC intelligence team consumes CTI intelligence report covering latest tactics employed by threat actors relevant to the organisation 	SOC intelligence team categorises behaviour described into the report, deriving precise information on TTPs employed 	Using CTI data the SOC intel team and blue team devise a strategy aimed at hunting specific tactics in line with ATT&CKs framework <pre>1 // Name: MSHTA - Process 2 // Description: Checks for execution of MITRE ATT&CK T1170 3 // 4 // Severity: High 5 // 6 // QueryFrequency: 1h 7 // 8 // QueryPeriod: 1h 9 // 10 // AlertTriggerThreshold: 1 11 // 12 // DataSource: #Sysmon 13 // 14 // Tactics: #Defense Evasion #Execution 15 // 16 Sysmon 17 where EventID == 1 18 and (process_command_line contains "mshta.exe" 19 or process_parent_command_line contains "mshta.exe")</pre>	The queries are executed within the detection technology and any positive hits are recorded and investigated 	Queries are deployed within SIEM to monitor for future recurrences of the adversary behaviour detected 

Threat hunting – hunting through dashboards

Once successful hunting hits are converted into detection rules and uploaded within monitoring of dashboards the execution of future hunts across the IT estate is drastically simplified as seen in the demo below:



Break

10 minutes

Part II

Introduction to Red Teaming concepts

What is red teaming

Definition

*"A group of people **authorized** and organized to **emulate a potential adversary's attack** or exploitation capabilities against an enterprise's security posture. The Red Team's objective is to improve enterprise cybersecurity by demonstrating the impacts of successful attacks and by demonstrating what works for the defenders (i.e., the Blue Team) in an operational environment. Also known as Cyber Red Team."*

From the [National Institute of Standards and Technology, Information Technology Laboratory, Computer Security Resource Centre's glossary of terms](#)

Why use red teaming

*"targeted attacks are primarily used for earning financial gain, conducting industrial espionage, stealing intellectual property, disrupting business processes, making political statements, and subverting operations on nation's critical infrastructure. Overall, **targeted attacks are complex in nature** because attackers have to invest a substantial amount of time in selecting targets, preparing attack models and discovering zero-day vulnerabilities. **Attackers behind the targeted attacks are experts in technology, and are highly motivated to pursue intrusion campaigns**"*

[Targeted Cyber Attacks, A. Sood & R. Enbody, 2014, Syngress](#)

- Today's businesses are faced with a threat landscape that doesn't just include opportunistic attackers, but also sophisticated, organised groups
- Red teaming provides a framework that attempts to test a company's resilience against sophisticated and persistent cyber attacks

Overview of key red teaming concepts

There are a number of differences between traditional penetration testing and red teaming, as outlined in the table below:

Difference	Aim	Methodology	Scope	Effort and duration	Cost
Penetration testing	Find and report vulnerabilities within IT software	Security assessment based on standardized methodologies (e.g. NIST 800-115)	Based on a tightly defined scope restricted to specific IT software or hardware assets	2 weeks minimum	Contained costs, typically sold as a commodity
Red teaming	Test an organisation's ability to detect and respond	Multi-phased security assessment that is intelligence-led	Based on a looser scope aligned with defined threat scenarios and leveraging multiple attack vectors	9 months	High costs and demanding large time investments

Red teaming – practical example

A generic red teaming engagement broadly follows the steps and concrete outputs as outlined in the table below:

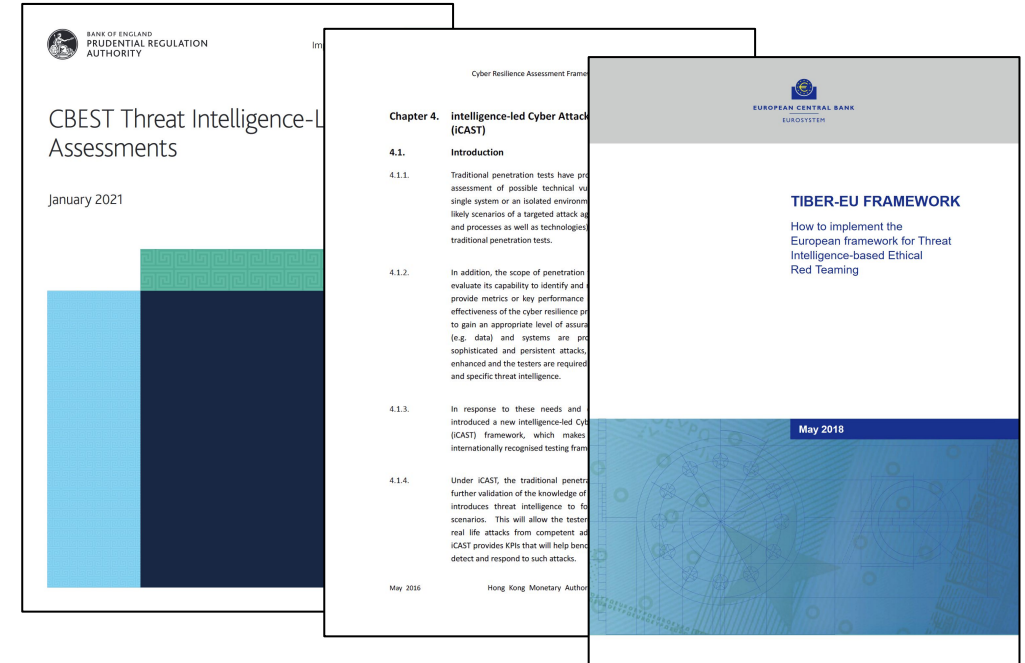
Objective setting	Procurement	Intelligence gathering	Penetration testing	Reporting
The target firm is selected for testing by the regulator on the basis of specific regulatory criteria or, alternatively, decides to independently trigger a red team exercise as part of a cyclical testing plan	The target firm begins by procuring the services of a threat intelligence and penetration testing provider, this is done via a request for proposals	The threat intelligence (TI) provider gathers intelligence and designs scenarios tailored to the target firm	The penetration testing assessment is performed by prescriptively executing the attack scenarios developed by the TI provider	The results of the assessment are detailed in a testing report that outlines all findings and associated remediation steps

Red teaming – intelligence led testing

Intelligence-led penetration testing is an approach that mimics the actions of cyber attackers' intent on compromising an organisation's important business services and disrupting the technology assets, people and processes supporting those services.

There are a number of frameworks governing such tests:

- CBEST - developed by the Bank of England
- TIBER - developed by the European Central Bank
- iCAST - developed by the Hong Kong Monetary Authority



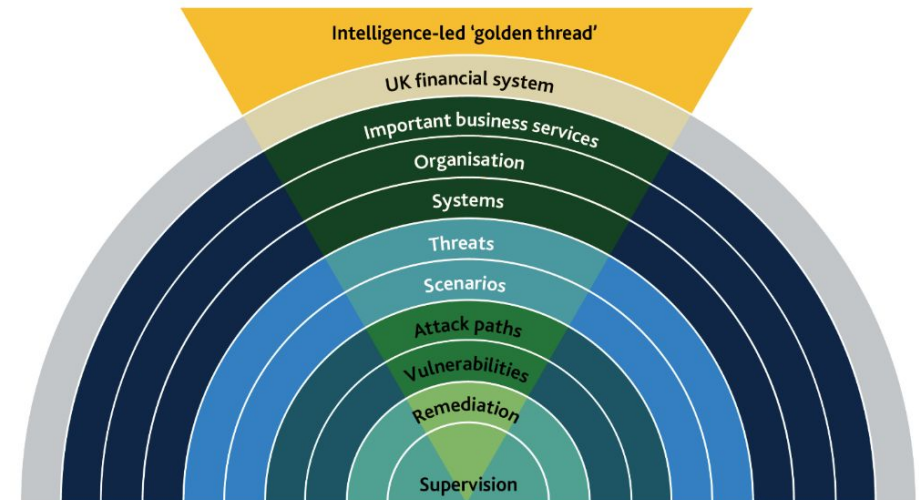
Screenshots of CBEST, iCAST and TIBER red teaming framework cover pages

Red teaming – CBEST overview

What differentiates CBEST from other security testing regimes is its intelligence-led approach ...this approach means that an organisation's activities are traceable to their role in supporting the wider economy, and the credible threats that the organisation faces in undertaking that role.

A CBEST assessment is carried out if one of the following criteria are met:

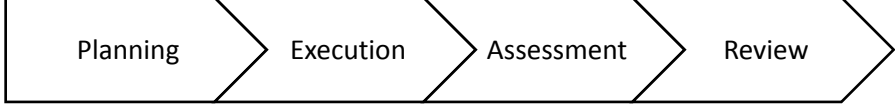
1. The target firm is one of the 'core' target group for the regulator who are required to undertake a CBEST
2. The target firm has requested to undertake a CBEST as part of its own cyber resilience programme
3. An incident or other events have occurred which has triggered the regulator to request a CBEST



Screenshots of CBESTs "golden thread" describing the importance of intelligence-led testing as the thread that holds the framework together and gives it value. Page 3, CBEST Threat Intelligence-Led Assessments Implementation Guide, January 2021, Bank of England

Red teaming – CBEST assessment phases

A CBEST engagement is broken down into four phases, each serving a specific function within the assessment, as described in the table below:

Initiation phase	• Project is started • The regulator contacts the target firm and ensures all relevant authorities are informed and on boarded • Timetable is established and suppliers are procured	 <pre>graph LR; Launch --> Engagement --> Scoping --> Procurement</pre>
Threat Intelligence phase	• Threat Intelligence Services Provider (TISP) is selected • Threat scenarios are defined and drafted into a testing plan • Testing plan is validated between the parties involved in the test • Plan is assessed and approved by the regulator	 <pre>graph LR; Direction --> Intelligence --> Validation --> Assessment</pre>
Penetration testing phase	• Scope of test is reviewed and finalised • The test is then executed in line with the threat scenarios identified during the threat intelligence phase • The target firm's detection and response capabilities are reviewed	 <pre>graph LR; Planning --> Execution --> Assessment --> Review</pre>
Closure Phase	• The findings emerging from the penetration testing phase are reported and a remediation plan is drafted • A debrief is performed between all parties involved in the test to review the execution of the assessment, remediation plan and deliverables • The remediation plan is implemented under regulatory supervision	 <pre>graph LR; Remediation --> Debrief --> Supervision --> Analysis</pre>

Red teaming – output and reporting

The penetration testing report is the most important output of the red team exercise as it outlines in detail the attacks performed and which ones were successful. A good penetration testing report provides to the target firm detailed recommendations explaining how to remediate the vulnerabilities discovered during the test. In general a good penetration testing report should also contain:

- Executive summary
- Overview of testing scope and threat scenarios assessed
- Testing approach
- Findings broken down by testing domain (e.g. mobile, network, social engineering vulnerabilities etc.) and each containing detailed remediation recommendations
- Testing limitations and risk scorings

An excellent example of a good penetration testing report can be found [HERE](#)

Red teaming - disadvantages

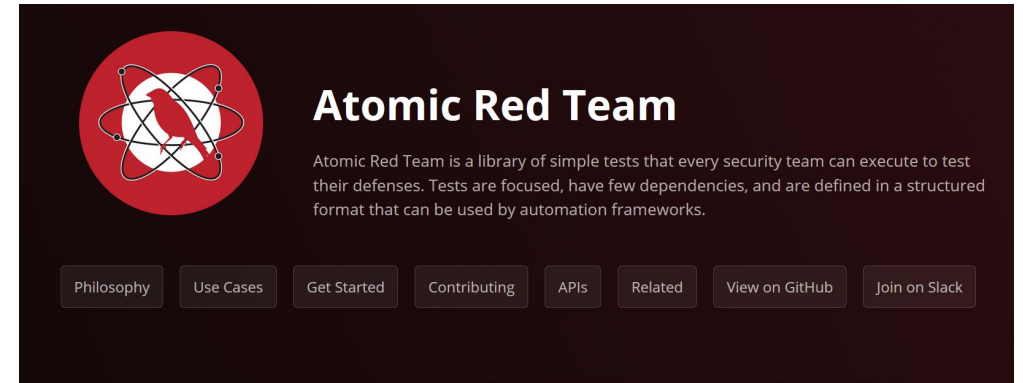
Although red teaming provides the most advanced form of penetration testing available to industries and markets today, these assessments do not offer a fool proof solution to securing organisations. In fact a number of disadvantages affect red teaming engagements:

- They are complex and expensive, generating a low commercial appetite for organisation to execute them
- The scope is limited to specific attack scenarios and techniques. Real attackers are not limited by a specific scope and are free to utilise any technique to achieve a foothold in the target organisation
- The engagement time is limited to a specific timeframe. Real attackers have no time limitation and can attack a target persistently for many months
- They are sophisticated forms of testing which function best when executed within the context of wider information security programs. Many organisations execute red teaming engagements without first implementing a functional basic information security program.

Red team alternatives - atomic red teaming

Atomic red teaming is a testing framework premised on the following principles:

- Tests are small and highly portable
- Tests are mapped to the MITRE ATT&CK Framework. Each test is designed to map back to a particular tactic.
- Tests are designed to offer defenders a highly actionable way to immediately start testing their defenses against a broad spectrum of attacks



Using Atomic Red Team to test your security

Our Atomic Red Team tests are small, highly portable detection tests mapped to the MITRE ATT&CK Framework. Each test is designed to map back to a particular tactic. This gives defenders a highly actionable way to immediately start testing their defenses against a broad spectrum of attacks.

Atomic Test #1 - System Service Discovery

Identify system services

Screenshot of Atomic Red Team home page

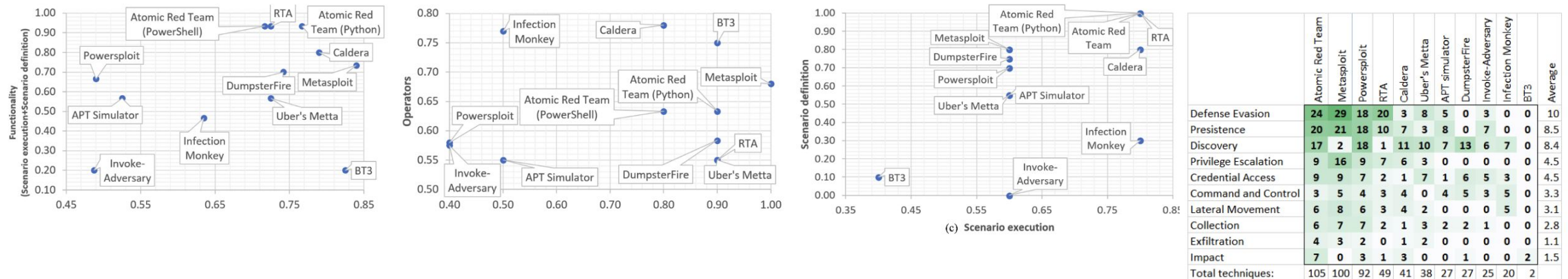
Why use Atomic Red teaming

Atomic Red Teaming (ART) offers a mature testing framework that is well established and used by organisations across the globe today. The framework presents the below advantages and disadvantages:

Advantages	Disadvantages
• Tests can be executed rapidly in less than five minutes • Tests are mapped to specific adversary behaviour • Tests are aimed at testing specific security controls • Tests produce concrete outcomes with defined remediation steps • Tests can be applied against processes and technologies	• Tests are limited to known attacker tactics and techniques • Tests are based on the ATT&CK taxonomy, if that changes then ART must be adapted • Tests rapidly become redundant • New tests being developed are subject to the ATT&CK framework being updated

Why use Atomic red teaming

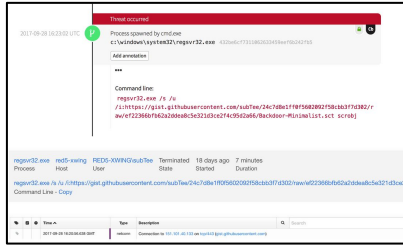
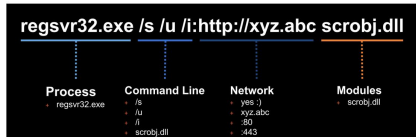
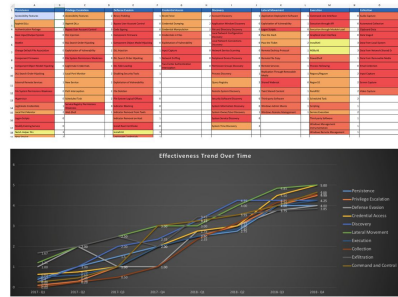
In a 2020 academic survey of threat emulators, atomic red teaming scored as one of the top threat emulation frameworks that blue teams can use today when evaluated on the basis of functionality as well as coverage of threat actors, threat scenarios and attack techniques, as evidenced in the images below:



Screenshots from [SoK: A Survey of Open-Source Threat Emulators](#), P.Zilberman, R.Puzis, S. Bruskin, S. Shwarz and Y. Elovici, arXiv:2003.01518v2 [cs.CR] 2 Oct 2020

How to use atomic red teaming

As detailed on the ART website, at a high level tests are executed across five phases, as detailed below:

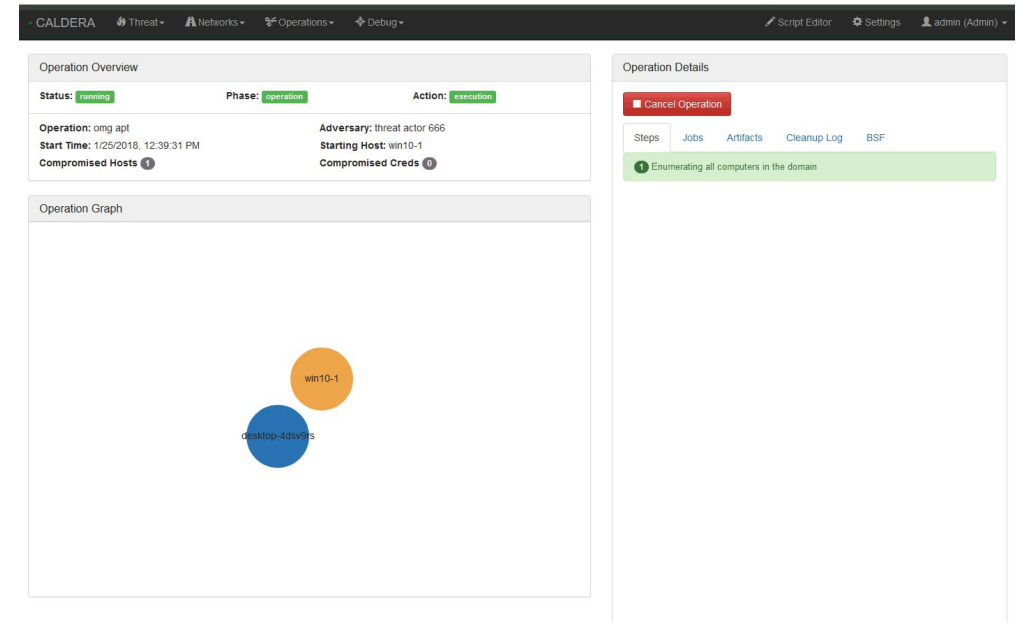
Select a test	Execute test	Collect evidence	Develop detection	Measure progress																
Following the development of a testing plan tests can be selected from ARTs repository covering Win, MacOS & Linux All Atomic Tests by ATT&CK Tactic & Technique privilege-escalation • T1546.004 lsass_profile and lsasshvc - Atomic Test #1: Add command to lsasshvc [macos, linux] - Atomic Test #2: Add command to lsasshvc [macos, linux] • T1548 Abuse Elevation Control Mechanism CONTRIBUTE A TEST • T1134 Access Token Manipulation CONTRIBUTE A TEST • T1546.008 Accessibility Features - Atomic Test #1: Attaches Command Prompt as a Debugger to a List of Target Processes [windows] - Atomic Test #2: Replace binary of sticky keys [windows] • T1546.009 AppCert DLLs CONTRIBUTE A TEST • T1546.010 AppInit DLLs - Atomic Test #1: Install AppInit Shim [windows] • T1546.011 Application Shimming - Atomic Test #1: Application Shim Installation [windows] - Atomic Test #2: New shim database files created in the default shim database directory [windows] - Atomic Test #3: Registry key creation and/or modification events for SDB [windows] • T1055.004 Asynchronous Procedure Call - Atomic Test #1: Process Injection via CF [windows] • T1053.001 At [linux] - Atomic Test #1: At - Schedule a job [linux] • T1053.002 At [windows] - Atomic Test #1: At.exe Scheduled task [windows] • T1547.002 Authentication Package CONTRIBUTE A TEST • T1547 Boot or Logon Autostart Execution CONTRIBUTE A TEST • T1037 Boot or Logon Initialization Scripts CONTRIBUTE A TEST • T1548.002 Bypass User Account Control	Once tests are selected these are executed by following the specific commands provided within ARTs repository Atomic Test #1 - Regsvr32 local COM scriptlet execution Regsvr32.exe is a command-line program used to register and unregister OLE controls. Upon execution, call: Supported Platforms: Windows <table><tr><th>Name</th><th>Description</th><th>Type</th><th>Default Value</th></tr><tr><td>filename</td><td>Name of the local file, include path.</td><td>Path</td><td>PathToAtomicFolder\T1218.010\src\Re</td></tr><tr><td>regsvr32path</td><td>Default location of Regsvr32.exe</td><td>Path</td><td>C:\Windows\system32</td></tr><tr><td>regsvr32name</td><td>Default name of Regsvr32.exe</td><td>String</td><td>regsvr32.exe</td></tr></table> Attack Commands: Run with <code>command_prompt1</code> <pre>#(regsvr32path)%(regsvr32name) /s /u /i:(/!(filename)) scrobj.dll</pre> Dependencies: Run with <code>powershell1</code> Description: Regsvr32.exe must exist on disk at specified location (#(filename)) Check Prereq Commands: <pre>if (Test-Path #(filename)) {exit 0} else {exit 1}</pre> Get Prereq Commands: <pre>New-Item -Type Directory (split-path #(filename)) -ErrorAction Ignore Out-Null Invoke-WebRequest "https://github.com/redcanaryco/atomic-red-team/raw/master/atomic/T1218.010/src/Re</pre>	Name	Description	Type	Default Value	filename	Name of the local file, include path.	Path	PathToAtomicFolder\T1218.010\src\Re	regsvr32path	Default location of Regsvr32.exe	Path	C:\Windows\system32	regsvr32name	Default name of Regsvr32.exe	String	regsvr32.exe	Detection solutions are then used to detect evidence of the tests being executed. All detection are recorded and the information reported is examined 	If any tests are not detected then detection analytics are developed in order to ensure that the tests cannot slip past undetected in the future 	Tests are re-executed periodically and detections incrementally developed. Improvements in the capability to detect ART tests are tracked over time 
Name	Description	Type	Default Value																	
filename	Name of the local file, include path.	Path	PathToAtomicFolder\T1218.010\src\Re																	
regsvr32path	Default location of Regsvr32.exe	Path	C:\Windows\system32																	
regsvr32name	Default name of Regsvr32.exe	String	regsvr32.exe																	

Screenshots are taken from ARTs [GitHub](#) and [getting started](#) pages

Alternatives – MITRE caldera

MITRE caldera – which stands for **Cyber Adversary Language and Detection Engine for Red team Automation** - is a cyber security framework designed to easily automate adversary emulation, assist manual red-teams, and automate incident response.

It is also based on MITRE ATT&CK and aims to automate the effectiveness of detection technologies and response processes against known adversary behaviours in a manner that is fully automated as possible.

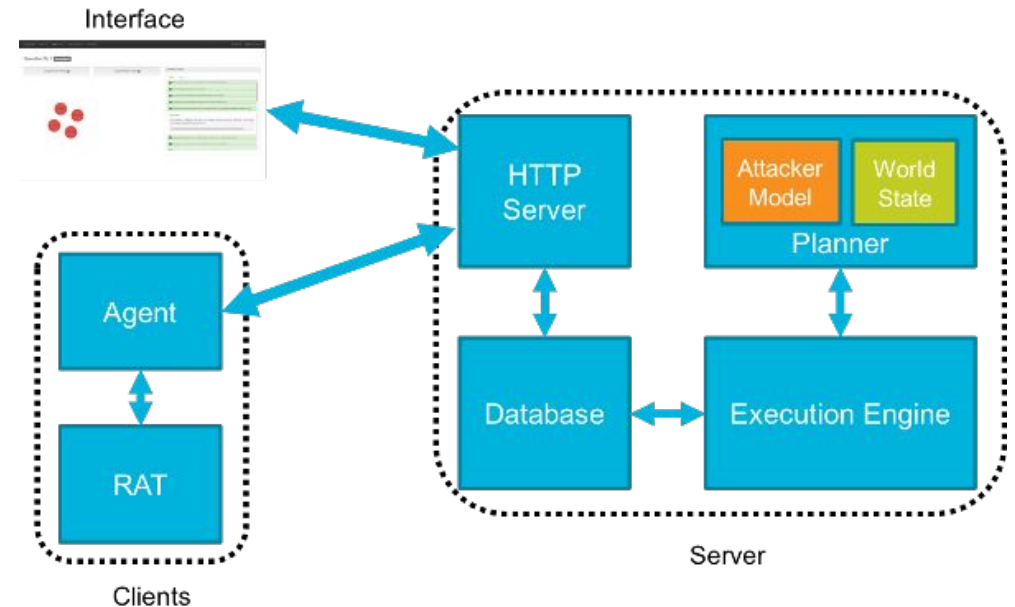


Screenshot of CALDERA operation in action

Caldera – how does it work

MITRE caldera is based on a server-agent architecture and relies on two components:

- **The core system.** This is the framework code, consisting of what is available in this repository. Included is an asynchronous command-and-control (C2) server with a REST API and a web interface.
- **Plugins.** These are separate repositories that hang off of the core framework, providing additional functionality. Examples include agents, GUI interfaces, collections of TTPs and more.



Screenshot of CALDERA architecture

Caldera – advantages and disadvantages

MITRE CALDERA offers a testing framework that prioritises automation. The framework presents the below advantages and disadvantages:

Advantages	Disadvantages
• Tests emulate adversary behaviours • The framework can be used to automate tests across an enterprise's entire endpoint estate • The framework tests both detection and response • The framework is free to use • The framework can also be used in training scenarios	• Tests are limited to known attacker tactics and techniques • Tests are based on the ATT&CK taxonomy, if that changes then ART must be adapted • The framework and tests cannot be set up rapidly • The framework is best leveraged in test environments and network labs

Part III

SOC emulation lab set-up tests

Lab detection infrastructure – Sign in tests

We will now perform some set-up and tests to ensure you can connect to the SOC emulation lab:

1. Connect to Azure SOC lab

- I. Connect to <https://www.portal.azure.com>
- II. Log in with your HSLU student account
- III. Upon successful login, you should be redirected to the azure home page
- IV. In the top search bar, type in the words "All resources"
- V. Select the "All resources" menu option that appears in the drop-down
- VI. Check that all resources appear in the resources overview page (see picture on right)



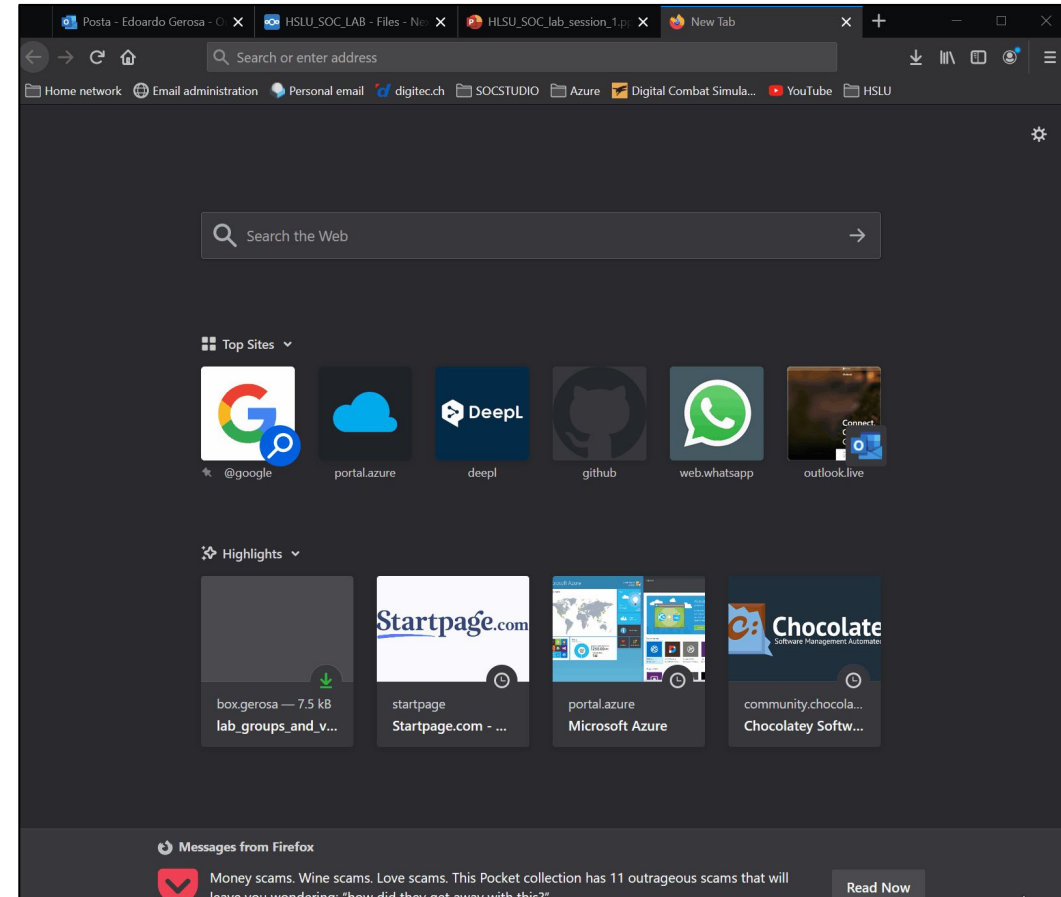
2. Access the README and lab exercise folder

- I. The README and lab exercise folder are found in ILIAS
- II. The lab exercise folder contain the following files:
 - A file named *lab_groups_and_vm_allocations.pdf* which lists your student group and VM name
 - Two additional PDF files to be used as part of the SOC LAB exercises
- II. The lab README file is also found in the lab exercise folder

Lab detection infrastructure – lab tests

We will now perform some tests to ensure you can connect and use the SIEM:

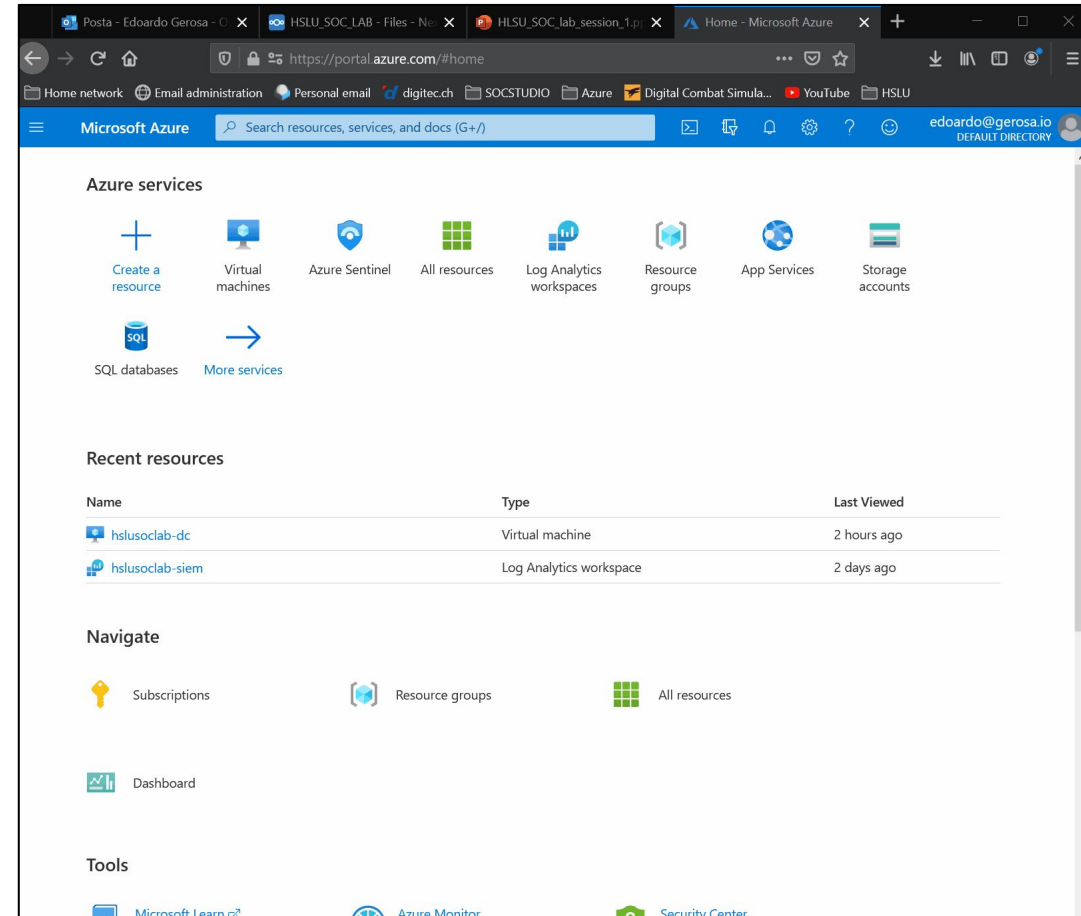
- SIEM connectivity test
 1. In the top search bar, type in the words "Azure Sentinel"
 2. Select the "Azure Sentinel" menu option that appears in the drop-down
 3. Double-click on the "hsl-siem" resource
 4. You should be redirected to the Azure Sentinel - Overview page



Lab detection infrastructure – lab tests

We will now perform some tests to ensure you can connect and use your virtual machine:

- Virtual machine connectivity test
 1. In the top search bar, type in the words "Virtual machines"
 2. Select the "Virtual machines" option
 3. Double click on the virtual machine resource
 4. Check the "Status" of your machine
 5. If the "Status" is set to "Stopped (deallocated)" double-click on the "Start" button
 6. If the "Status" is set to "Running" click on the "Connect" button
 7. Double click on the "Download RDP File" button
 8. A download prompt will open, accept the download and open the RDP file
 9. Connect to the virtual machine



Thank you for your attention